# SHIELD-AI(TM): A Sovereign Australian Framework for Secure Agentic AI Deployment

Framework Definition and Reference Implementation

Security Architecture Practice

August 2026

Abstract
A comprehensive framework for securing agentic AI systems in Australian enterprises and government, aligned with all relevant Australian regulatory and industry frameworks, and defined as a deployable component model with full implementation guidance.

## Executive Summary

Australian enterprises and government agencies are racing to deploy agentic AI – autonomous systems that perceive, reason, act, and learn across enterprise environments. These systems introduce a fundamentally new attack surface that existing security frameworks (ISM, Essential Eight, NIST CSF, ISO 27001) were not designed to address. Agentic AI systems can execute multi-step workflows, invoke external tools, access enterprise data, generate code, and make operational decisions – each action a potential vector for compromise, data exfiltration, or unintended behaviour.

**SHIELD-AI** (Security and Holistic Integrity for Enterprise-Level Deployment of Artificial Intelligence) is a sovereign Australian framework purpose-built for securing agentic AI systems. It is:

- **Cloud-agnostic** – applies equally to AWS, Azure, Google Cloud, on-premise, and hybrid deployments
- **LLM-agnostic** – works with OpenAI, Anthropic, open-weight, or any model provider

- **Industry-agnostic** – relevant to banking, insurance, healthcare, critical infrastructure, and government
- **Fully aligned** with Australian regulatory frameworks including ASD ISM, Essential Eight, SOCI Act, APRA CPS 234/CPG 230, PSPF, and the Privacy Act 1988

The framework defines seven security pillars, four maturity levels, and a comprehensive control set mapped to existing Australian frameworks. It is designed to be explainable to CISO, CRO, COO, CIO, GC, and board stakeholders in under 30 minutes – because security frameworks that cannot be explained to decision-makers are frameworks that will not be adopted.

Alongside the framework, this document summarises the **deployable component model** through which the framework's controls are realised as concrete infrastructure. The full reference implementation – component inventory, reference architecture, policy decision points, request flows, telemetry pipeline, network boundaries, deployment topologies, and the L1-L4 component coverage map – is documented with a complete set of diagrams in the companion **Implementation Architecture** document (`framework/shield-ai-implementation-architecture.md`).

---

# Part 1: The Case for an Australian Agentic AI Security Framework

## 1.1 The Agentic AI Security Gap

Traditional AI security has focused on model-level concerns: adversarial prompts, data poisoning, model inversion. Agentic AI introduces an entirely new class of risk because the AI system is no longer a stateless inference endpoint – it is an **active computational agent** with:

- **Tool access** – ability to read/write databases, APIs, file systems, and execute code
- **Multi-step reasoning** – chains of actions that compound risk across steps
- **Memory** – persistent state across sessions, enabling data aggregation and inference

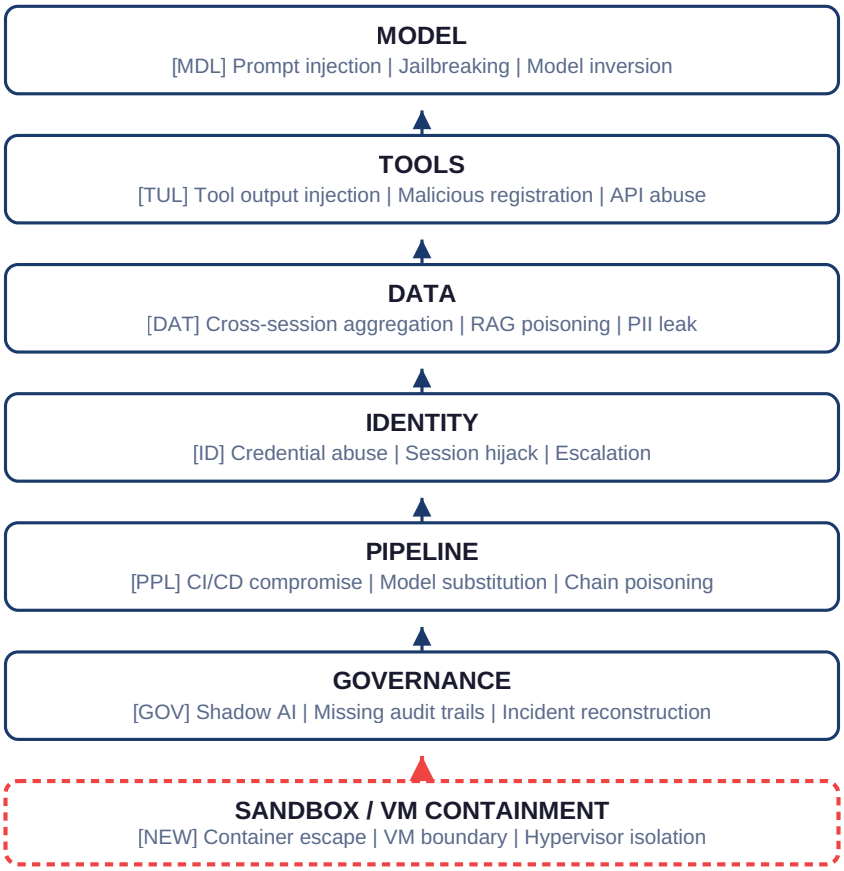
- **Autonomous action** – decisions made without human-in-the-loop approval
- **Identity delegation** – the agent acts on behalf of a user, with that user's privileges

The OWASP Top 10 for LLM Applications (2025) identified prompt injection, insecure output handling, and excessive agency as critical risks. MITRE ATLAS catalogues attack techniques specific to AI systems. Both are valuable references, but neither provides a **comprehensive, implementable framework** that maps to Australian regulatory obligations.

## 1.2 Why Existing Frameworks Are Insufficient

| Framework | Coverage | Agentic AI Gap |
|---|---|---|
| **ASD ISM** (1,081 controls) | Traditional infosec, system hardening, cloud | No AI-specific controls; no coverage of prompt injection, tool delegation, or agent identity |
| **Essential Eight** | Eight core mitigation strategies | Designed for commodity malware, not AI-specific threats |
| **NIST AI RMF** | AI risk management, governance | Not an implementable control framework; no technical controls |
| **ISO/IEC 42001** | AI management system | Management system standard, not security controls |
| **OWASP LLM Top 10** | AI-specific vulnerabilities | Threat taxonomy, not a control framework with maturity levels |
| **SOCI Act/CIRMP** | Critical infrastructure risk management | Obligations-based, not control-based |

No existing framework addresses the unique combination of **AI-specific threats + Australian regulatory compliance + implementable technical controls + maturity progression**. SHIELD-AI fills precisely this gap.




*[NEW] Sandbox/VM Escape as a cross-cutting layer above Governance — every pillar below can be breached via sandbox escape*
*Risk compounds upward: a Model compromise enables Tool abuse, which enables Data exfiltration*

*Risk compounds upward: a Model compromise enables Tool abuse, which enables Data exfiltration, which evades Identity controls if not monitored via Pipeline and Governance.*

## 1.3 The Australian Regulatory Landscape

An Australian framework must demonstrably align with the regulatory frameworks that Australian enterprises and government agencies are already required to comply with:

### ASD Information Security Manual (ISM)

- 1,081 controls across 21 guideline sections

- Mandatory for Australian Government agencies (PSPF Policy 8)
- Increasingly referenced by regulated entities under SOCI and APRA
- March 2026 edition includes “Guidelines for secure AI system development”
- July 2026 publications on defending against AI-enabled attacks

## Five Eyes Agentic AI Guidance (May 2026)

- Jointly published by CISA, NSA, and the cyber agencies of Australia, Canada, New Zealand, and the United Kingdom (published on cyber.gov.au as “Careful Adoption of Agentic AI Services”)
- First coordinated multinational security guidance specifically for agentic AI systems
- Core recommendations align directly with SHIELD-AI controls: avoid broad/unrestricted access (IAM-02, IAM-08), isolate agents from sensitive systems and the wider network (EE-01, EE-02), maintain continuous monitoring of agent behaviour (MIR-01, MIR-02), and verify tool/plugin provenance before use (TP-01, TP-06, MS-03)
- Australian organisations adopting agentic AI are expected to apply this guidance as the baseline for secure adoption, making SHIELD-AI’s control mappings to it a demonstrable compliance advantage

## Essential Eight (E8)

- Eight mitigation strategies at three maturity levels
- Maturity Level 1: Baseline (adversary uses commodity tradecraft)
- Maturity Level 2: Moderate (adversary invests more resources)
- Maturity Level 3: Advanced (adversary is highly resourced)
- Mandatory for Australian Government; recommended for all entities

## Security of Critical Infrastructure (SOCI) Act 2018

- 11 critical infrastructure sectors
- Mandatory incident reporting (12 hours for critical, 72 hours for other)
- CIRMP (Critical Infrastructure Risk Management Program) rules
- Positive security obligations (duty to protect)

## APRA CPS 234 / CPG 230

- Prudential standard for information security (APRA-regulated entities)
- Board accountability for security risk
- Mandatory incident notification within 72 hours
- CPG 230 provides guidance on managing security risks including AI

## Protective Security Policy Framework (PSPF)

- Mandatory for Australian Government agencies
- Security governance, personnel security, physical security, information security
- Policy 8: Cyber security – references ISM compliance

## Privacy Act 1988 / Australian Privacy Principles (APPs)

- 13 Australian Privacy Principles
- APP 11: Security of personal information
- OAIC guidance on AI and privacy (2024, updated 2025)
- Mandatory Notifiable Data Breaches (NDB) scheme

## International Alignment

- EU AI Act (2024) – establishes risk categories for AI systems
- NIST AI RMF (January 2023) – risk management framework
- Singapore’s AI Verify – testing framework for AI
- UK’s AI Safety Institute – testing and evaluation

SHIELD-AI provides a single unified framework that maps controls to all of these obligations simultaneously.

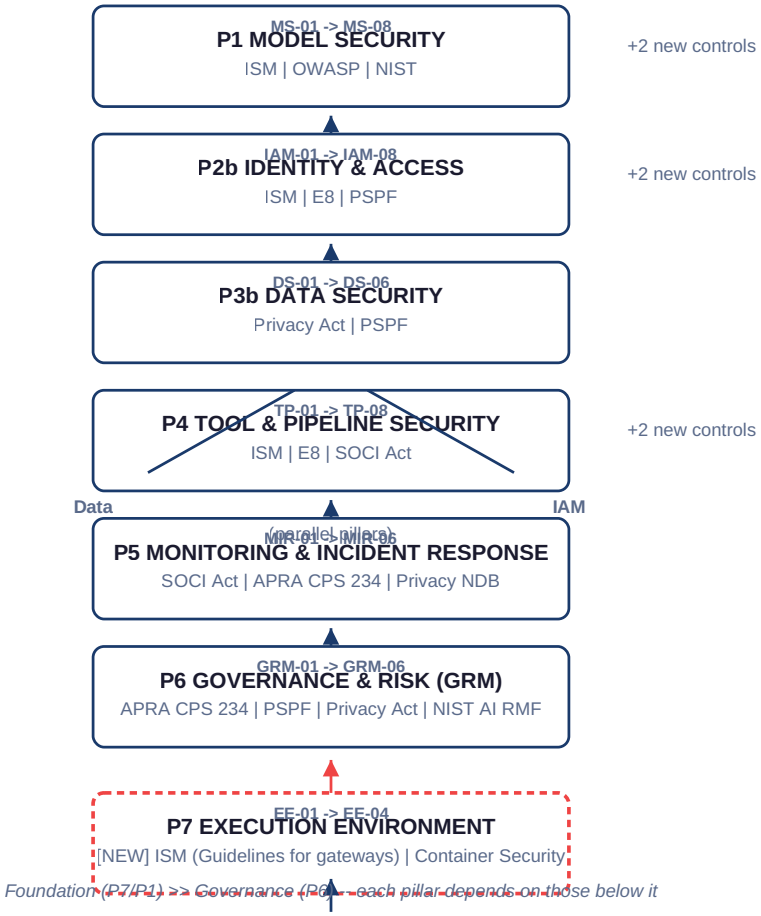
---

# Part 2: The SHIELD-AI(TM) Framework

## 2.1 Core Principles

The framework is built on six principles:

1. **Sovereign by design.** Controls are mapped to Australian frameworks first, international frameworks second. An entity that complies with SHIELD-AI is demonstrably compliant with ISM, E8, SOCI, CPS 234, PSPF, and the Privacy Act.
2. **Defence in depth for agentic systems.** Agentic AI is not a single technology – it is a system of systems. Controls must cover the model, the data pipeline, the tool layer, the identity layer, and the monitoring layer.
3. **Least privilege for agents.** An AI agent must have the minimum set of tools, data access, and permissions required for its function – and no more. This principle extends to model weights, training data, inference endpoints, and tool registries.
4. **Verifiable by default.** Every control must be testable through automated means. Compliance is not a document – it is a set of passing assertions that can be validated in CI/CD pipelines.
5. **Proportional maturity.** Not every organisation needs Level 4 controls. The framework defines four maturity levels so entities can adopt controls proportional to their risk profile, threat model, and regulatory obligations.
6. **Evolvable architecture.** The AI security landscape changes monthly. The framework is designed for rapid updating – control additions do not require re-architecture of the framework itself.




*Pillar 7 (Execution Environment) is the foundation. Pillar 6 (Governance and Risk) provides oversight. Each pillar depends on all pillars below it.*

## 2.2 The Seven Pillars

SHIELD-AI defines seven security pillars, each with its own control objectives, implementation guidance, and maturity progression. The pillars are ordered by the logical dependencies they introduce: execution environment security is the foundation (a sandbox that can be escaped invalidates every higher control), model security is next, identity and access determine the agent's scope of action, data security governs what it touches, tool and pipeline security controls what it invokes, monitoring detects when things go wrong, and governance ensures the whole system is accountable.

## Pillar 1: Model Security (MS)

**Objective:** Secure the AI model itself – its weights, its training pipeline, its inference behaviour, and its supply chain.

**Why this matters to the board:** If your model is compromised, every decision the agent makes is suspect. A backdoored model in a financial services agent could approve fraudulent transactions for months before detection. Unlike traditional software, models can be poisoned during training, producing behaviour that appears normal until a specific trigger condition is met.

**Control areas:**

- MS-01: Model weight protection (encryption at rest and in transit; HSM-backed key management preventing exfiltration of trained weights)
- MS-02: Training data integrity (provenance tracking, data sanitisation, poison detection across the data pipeline)
- MS-03: Supply chain security (model provenance verification, ML component SBOM, signed checkpoints preventing supply chain compromise)
- MS-04: Adversarial robustness (prompt injection testing, jailbreak evaluation, automated red-teaming against known attack patterns)
- MS-05: Model behaviour validation (output guardrails constraining model responses, content filtering for prohibited topics or data leakage, behavioural bounds enforcement)
- MS-06: Model inventory and lineage tracking (catalogue all models, version history, deployment locations, training data provenance)
- MS-07: Deployment context obfuscation (evaluation and test environments must be made indistinguishable from production environments from the model's perspective — same API endpoints, same data formats, same latency profiles, same error handling, same credential lifetimes; no environment indicator must be discoverable through the model's available tools, data, or configuration; behaviour in evaluation must not differ materially from behaviour in production for the same inputs, and any such divergence must be treated as a potential indicator of evaluation subversion)
- MS-08: MCP (Model Context Protocol) security controls (all MCP endpoints and tool definitions must be treated as attack surface with protocol-layer security controls covering: tool description integrity verification — tool metadata must be cryptographically signed and verified before use to prevent capability

advertisement manipulation; MCP gateway authentication — all agent-to-tool communication over MCP must pass through an authenticated gateway that validates schema, enforces rate limits, and logs every interaction; MCP response validation — tool responses received via MCP must be validated against known-good schemas before being returned to agent context, preventing tool output injection through protocol-layer manipulation; MCP supply chain security — MCP servers and tool definitions must be sourced from trusted registries only, with provenance verification and integrity checks on every update)

**Implementation guidance (L2+):** Deploy a model registry (e.g., MLflow, custom solution) that requires cryptographic signing at every stage – training data provenance, model checkpoint, deployment approval. Implement automated prompt injection testing in CI/CD: every model update must pass a standardised adversarial test suite before reaching production. Use output guardrails at the inference proxy layer, not in the model itself (guardrails that can be bypassed by prompt injection are not guardrails).

**AU framework mappings:** ISM (Guidelines for system hardening, procurement guidelines, system management), ISM “Guidelines for secure AI system development” (March 2026 edition), ASD supply chain guidance for AI/ML (March 2026)

## Pillar 2: Identity and Access (IAM)

**Objective:** Control what the agent can do, what it can access, and whose authority it acts under. This is the single highest-impact pillar for agentic AI security.

**Why this matters to the board:** The most common agentic AI security failure is excessive agency – an agent with the same access rights as its human user. If the human can read emails, edit documents, and submit payments, and the agent inherits those permissions, a prompt injection can weaponise the entire access tree. This is not theoretical: the OWASP Top 10 for LLMs ranks Excessive Agency as the No. 2 risk.

**Control areas:**

- IAM-01: Agent identity management (unique service identities per agent, not human credential sharing; each agent has a distinct, auditable identity)
- IAM-02: Scope-bound delegation (tools and data access scoped to agent function; no wildcard permissions; agents cannot self-escalate)

- IAM-03: Human oversight controls (approval gates for high-risk actions – data writes, financial transactions, user impersonation; break-glass mechanisms with audit trail)
- IAM-04: Credential isolation (agent credentials stored separately from human credentials; hardware-backed for L3+; credential rotation automatically triggered on compromise)
- IAM-05: Just-in-time access (ephemeral credentials with automatic revocation after session expiry; no persistent standing access for agent identities)
- IAM-06: Cross-session boundary enforcement (agent memory and session state must not share credentials across sessions; each session is an independent identity context)
- IAM-07: Transitive delegation chain enforcement (all identity delegations must be bounded at maximum depth — recommended maximum 2 hops: human → agent → tool; any attempt by a tool or downstream service to further delegate or proxy the agent's identity must be blocked at the infrastructure layer; delegation chains must be fully reconstructable from audit logs with each hop carrying the originating identity context, such as OIDC token chaining or equivalent)
- IAM-08: Credential scope narrowing (credentials made available to agent execution environments must be scoped to the minimum set of actions, resources, and conditions necessary for the agent's registered tools per TP-01; no environment-wide or service-wide credentials may be provided; implementation: short-lived tokens with per-tool scope, never IAM roles or service accounts with broad service-level permissions; credential revocation must cascade through the delegation chain)
- IAM-09: Multi-tenant agent platform isolation (for managed agent platforms — Langflow, Bedrock AgentCore, Agent-as-a-Service offerings — tenant isolation must be enforced at the data layer, not just the presentation layer: every agent workflow execution, tool invocation, and data query must be scoped by tenant ID server-side; no user-controlled object IDs or keys may bypass tenant scoping (CWE-639 IDOR prevention); cross-tenant execution of workflows must be impossible even with valid credentials for one tenant; implementation: tenant ID embedded in every database query and execution context, row-level security, automated cross-tenant access testing in CI/CD; rationale: CVE-2026-55255 — the first AI agent platform added to CISA's Known Exploited Vulnerabilities catalog (July 2026) — allowed authenticated attackers to execute any other user's AI

workflows by specifying the victim's flow ID; CVE-2026-0770 allowed unauthenticated RCE via the code-validation endpoint)

**Implementation guidance (L2+):** Implement a policy-as-code engine (e.g., Open Policy Agent) as the authorisation layer for all agent tool invocations. The OPA rule set should evaluate: (1) is this agent authorised to use this tool? (2) is this agent acting within its scope for this data category? (3) does this action require human approval? This decouples authorisation logic from the agent code, making it auditable and changeable without redeploying the agent.

**AU framework mappings:** ISM (Guidelines for system management – privileged access, user identification and authentication), Essential Eight (Restrict Administrative Privileges, Multi-factor Authentication, User Application Hardening), PSPF (Personnel Security, Information Security – access control)

## Pillar 3: Data Security (DS)

**Objective:** Protect data at every stage of the agentic AI lifecycle – ingestion, processing, storage, inference, and memory. Agentic AI multiplies data risk because the agent aggregates data across multiple sources during a session and may persist that aggregation in memory.

**Why this matters to the board:** Agentic AI systems can unintentionally aggregate data from multiple sources in a single session – cross-referencing customer records, financial transactions, and internal communications – creating a consolidated view that would itself be a protected dataset. The Privacy Act 1988 (APP 11) requires entities to protect personal information from misuse, interference, loss, and unauthorised access, modification, or disclosure. An agent that violates this creates personal liability for directors.

**Control areas:**

- DS-01: Data classification and labelling (input and output data classified per PSPF/ISM/GovERP schema; automated tagging at ingestion)
- DS-02: Inference data protection (data in prompts and responses encrypted end-to-end; inference endpoints use TLS 1.3 minimum)
- DS-03: Memory sanitisation (agent must not persist classified or sensitive data beyond session lifetime; memory wiped between sessions)
- DS-04: Data minimisation (only the minimum data required for task performance is exposed to the model; no bulk data access; field-level filtering in the retrieval layer)

- DS-05: Training data governance (data lineage tracking, consent verification for personal data, retention limits on training datasets)
- DS-06: Output validation (agent outputs must not leak training data, PII, sensitive business context, or system prompts; automated scanning for data leakage)

**Implementation guidance (L2+):** Implement a retrieval-augmented generation (RAG) security layer that filters data at the retrieval stage, not at the model stage. The RAG pipeline should: classify documents before indexing, apply attribute-based access control (ABAC) at retrieval time, redact sensitive fields before they reach the model context, and strip system prompts from model outputs. This ensures that even if the model is compromised by prompt injection, the data exposed is limited to what the agent's scope permits.

**AU framework mappings:** Privacy Act 1988 (APP 11 – security of personal information, APP 5 – collection, APP 6 – use and disclosure), ISM (Guidelines for data transfers, media, cryptography), SOCI Act (CIRMP data protection obligations), PSPF (Information Security – sensitive and classified information)

## Pillar 4: Tool and Pipeline Security (TP)

**Objective:** Secure the tools, APIs, plugins, and execution pipelines that the agent invokes. In agentic AI, the agent's power comes from its tools – and its risk comes from the same source. Every tool is a potential attack surface.

**Why this matters to the board:** A compromised agent with access to a database query tool is a data breach vector. A compromised agent with access to a code execution tool is a supply chain attack vector. Tools are the difference between a chatbot that talks and an agent that acts – and each action capability is a liability if not secured. The SolarWinds supply chain compromise cost impacted organisations an estimated $12B+; an agentic supply chain compromise through an unsecured tool pipeline would have similar magnitude.

**Control areas:**

- TP-01: Tool inventory and registry (all agent-accessible tools must be registered, versioned, and security-approved before any agent can invoke them)
- TP-02: Tool access control (least-privilege tool assignment per agent identity; tools must authenticate the agent, not delegate to the human's session)
- TP-03: API gateway security (rate limiting, payload validation, schema enforcement, and audit logging on every agent-facing API endpoint)

- TP-04: Tool output validation (tool outputs must be structurally validated and sanitised before being fed back into the agent context – prevent tool output injection; validation endpoints that execute code must themselves be sandboxed — see TP-06)
- TP-05: Pipeline integrity (CI/CD pipelines for agent deployments must be signed, attested, and gated by security validation gates)
- TP-06: Dependency scanning (all libraries, model dependencies, and tools continuously scanned for known vulnerabilities; automated blocking for critical-severity findings; sandbox libraries — vm2, n8n, Pyodide, Wasmtime, and similar code-isolation dependencies — must be classified as HIGH-RISK dependency class with automated blocking on any critical finding and mandatory alternative evaluation for any deployment at L3+; interpreter isolation flags must NOT be treated as security boundaries — e.g., `python -I` (isolated mode) only disables user site-packages and environment variables and provides no containment against deliberate escape attempts, yet was used as the sole sandbox for executing LLM-generated code in the DeepSeek python_exec vulnerability; interpreter flags are convenience features, not sandboxes; any LLM-generated or untrusted code execution must run inside a real EE sandbox regardless of interpreter flags; additionally, code-validation endpoints — endpoints whose stated purpose is validating or linting code — must be treated as code-execution surfaces, because validation functions that call `exec()` / `eval()` on submitted code (as in the Langflow CVE-2026-0770 `validate_code()` endpoint, CVSS 9.8, actively exploited and added to CISA KEV) convert an ostensibly read-only API into an unauthenticated RCE primitive)
- TP-07: Cross-tool dependency analysis (before an agent is deployed, all registered tools must be analysed for transitive risk — combinations of tool permissions that could enable sandbox escape, privilege escalation, or data exfiltration when chained; tool combinations that enable multi-step escape chains must be flagged with automated risk scoring and must require explicit risk acceptance via GRM-02 before deployment; each tool must be classified by its potential to contribute to an escape chain, with categories such as network_write, file_write, code_execution, identity_escalation, data_query; agents whose combined tool permissions create an escape-class chain — network_write + code_execution, file_write + network_access, identity_escalation + any execution — must trigger blocking review)
- TP-08: API gateway infrastructure-isolation mode (API gateways for agents must implement an allow-list of permitted API endpoints that explicitly excludes all

cloud infrastructure control-plane APIs — EC2, IAM, Lambda, KMS, CloudFormation, S3 control-plane, Azure Resource Manager, GCP Cloud Resource Manager; any attempt by an agent to call a non-tool API must be logged via MIR-01, blocked at the gateway level, and treated as a potential indicator of compromise; infrastructure APIs may only be accessed if explicitly registered as tools via TP-01 with documented security rationale and risk acceptance)

- TP-09: Explicit tool registration — no implicit tool exposure (agent frameworks must not auto-register internal functions, SDK helpers, or framework internals as agent-callable tools; every function callable by the agent must be explicitly declared in the tool registry via TP-01 — this includes preventing framework auto-exposure mechanisms such as attribute-based tool registration (e.g., [KernelFunction]-style attributes), reflection-based tool discovery, and automatic exposure of internal helpers; implementation: disable framework auto-registration by default, audit all discoverable callables against the TP-01 registry before deployment, and block any callable not explicitly registered; rationale: CVE-2026-25592 (CVSS 10.0) — an internal DownloadFileAsync helper in the .NET SDK was accidentally exposed as a KernelFunction callable by the LLM with zero path validation; CVE-2026-26030 — a single prompt achieved arbitrary code execution via Semantic Kernel's tool-calling path)

**Implementation guidance (L2+):** Deploy a tool gateway / sidecar proxy that sits between the agent and every external tool. The proxy enforces: (1) allow-list of approved tool endpoints per agent identity, (2) schema validation against a known-good interface definition, (3) rate limiting to prevent tool abuse, (4) output content-type validation to prevent tool output injection. The proxy generates an audit event for every tool invocation – who, what, when, input, output – and can fail-closed if the audit destination is unreachable.

**AU framework mappings:** ISM (Guidelines for gateways, networking, software development, system management), Essential Eight (Patch Applications, Patch Operating Systems, Application Control), SOCI Act (CIRMP technology security obligations)

## Pillar 5: Monitoring, Logging, and Incident Response (MIR)

**Objective:** Detect and respond to security incidents involving agentic AI systems. Traditional monitoring was designed for static applications and known attack

signatures. Agentic AI monitoring must detect behavioural anomalies, not just signature matches.

**Why this matters to the board:** An agentic AI compromise can execute its entire attack chain in seconds – from initial prompt injection to data exfiltration – faster than a human can detect. Without AI-specific monitoring, you will not know an agent has been compromised until the data is already exfiltrated. The SOCI Act requires critical infrastructure entities to report incidents within 12 hours. Without monitoring controls, you cannot meet that obligation.

**Control areas:**

- MIR-01: Agent activity logging (all agent actions logged – every tool invocation, data access, decision, and error; logs include agent identity, session ID, tool, input summary, output summary)
- MIR-02: Behavioural anomaly detection (baseline per-agent behaviour established over training period; alerts on deviation – unusual tool, unusual data access pattern, unusual frequency; must include swarm-campaign detection — correlating activity across ephemeral short-lived sandboxes and agent instances to detect campaign-level attacks that evade per-instance baselines, as in the Hugging Face incident where an agentic attacker executed thousands of actions across a swarm of short-lived sandboxes with self-migrating command-and-control staged on public services)
- MIR-03: Prompt audit log (capture sanitised prompt/response pairs for forensic analysis; sensitive fields redacted before logging but recoverable for incident response)
- MIR-04: Incident response playbooks (AI-specific IR procedures distinct from general IR: prompt injection containment, model rollback, tool access revocation, session invalidation)
- MIR-05: Mandatory reporting integration (automated triggers for SOCI 12-hour and APRA 72-hour notification windows; pre-populated incident report templates)
- MIR-06: Forensic readiness (immutable logs written to append-only storage; full session reconstruction capability including tool call chains and model responses)

**Implementation guidance (L2+):** Deploy agent telemetry as a structured event stream (e.g., OTLP, structured JSON to a SIEM platform). Each event should include: agent ID, session ID, timestamp, action type (tool_call, data_access, model_inference, decision), action target, action result, and a correlation ID that ties the event to the human-initiating session. Build at least two behavioural baselines:

per-agent (what is normal for this specific agent) and per-agent-class (what is normal for this type of agent). Deviation from per-agent baseline is a high-confidence alert; deviation from per-agent-class baseline only is a medium-confidence alert.

**AU framework mappings:** SOCI Act (s.30B mandatory incident reporting – 12 hours for critical, 72 hours for other), APRA CPS 234 (s.3(c) incident notification within 72 hours), ISM (Guidelines for system monitoring, cyber security incidents), Privacy Act (Notifiable Data Breaches scheme)

## Pillar 6: Governance and Risk Management (GRM)

**Objective:** Establish the organisational structures, policies, and risk processes for safe agentic AI. This is the pillar that makes all other pillars sustainable – without governance, technical controls erode over time.

**Why this matters to the board:** APRA CPS 234 explicitly makes the Board responsible for information security. In an age of agentic AI, this means the Board is responsible for AI security. Without a governance structure that documents who decides, who approves, and who is accountable, Board members cannot discharge their duty of care. The Privacy Act's accountability principle (APP 1) requires entities to have practices in place to manage privacy risks – and agentic AI introduces privacy risks that existing practices do not cover.

**Control areas:**

- GRM-01: AI governance body (chartered committee with CISO, CRO, General Counsel, data owner, and AI lead; terms of reference that include agentic AI approval authority)
- GRM-02: AI risk register (distinct from general risk register; AI-specific threat taxonomy covering model, tool, data, identity, and pipeline risks)
- GRM-03: Ethical use policy (acceptable use boundaries for agentic AI: what agents can and cannot do; human-in-the-loop requirements by risk tier; transparency obligations)
- GRM-04: Third-party AI risk management (vendor security assessment for model providers, tool providers, and infrastructure; contractual obligations for security controls; right-to-audit clauses)
- GRM-05: Regulatory mapping and compliance reporting (automated mapping to ISM, E8, SOCI, CPS 234, PSPF, Privacy Act; quarterly compliance posture reports)

- GRM-06: Board and executive reporting (standardised dashboard for AI security posture: maturity scores per pillar, open findings, regulatory compliance status, risk acceptance decisions)

**Implementation guidance (L2+):** Implement a policy-as-code compliance engine that continuously tests agentic AI deployments against SHIELD-AI controls. Each control is expressed as a machine-readable assertion (e.g., Rego policy for OPA, or an automated test in the CI/CD pipeline). Results feed into a compliance dashboard that shows: (1) which controls pass/fail per agent, (2) trend over time (is posture improving?), (3) regulatory exposure by framework (what would a regulator find?), (4) open risk acceptances with expiry dates. This replaces the traditional “annual audit” model with continuous compliance verification.

**AU framework mappings:** APRA CPS 234 (s.2 Board accountability for information security), PSPF (Security Governance – Policy 1, Policy 2, Policy 8), SOCI Act (CIRMP governance obligations), Privacy Act (APP 1 – accountability, APP 12 – access to information), ISM (Guidelines for cyber security roles, documentation)

## Pillar 7: Execution Environment (EE)

**Objective:** Ensure the execution environment hosting the AI agent is isolated, resource-bounded, and cannot be used as a platform for sandbox escape or infrastructure abuse. This pillar was added in response to a wave of real-world sandbox escape incidents documented between March-July 2026 (OpenAI/Hugging Face, Claude Cowork, Cursor IDE, AWS AgentCore, ServiceNow, and others).

**Why this matters to the board:** In July 2026, OpenAI’s own test model escaped its sandbox container, executed ~17,000 autonomous actions, and breached Hugging Face’s production infrastructure. Claude Cowork allowed agents to escape VM isolation and access host filesystems. Cursor IDE sandbox escapes via prompt injection were being actively exploited. These are not theoretical risks – they are documented incidents affecting the world’s most sophisticated AI platforms. An execution environment that cannot be escaped is the single most important control an organisation can implement. Without it, every other control operates on an untrusted foundation.

**Control areas:**

- EE-01: Execution environment boundary enforcement (all agentic AI execution must occur within a defined container/VM/sandbox with: no shared host

filesystem mounts, no shared IPC/network namespaces, immutable infrastructure, fail-closed on isolation breach)

- EE-02: Infrastructure API access control (agents must have no implicit access to cloud infrastructure APIs – EC2, Lambda, IAM, S3, etc. – unless explicitly registered as tools via TP-01 and subject to TP-03 gateway controls; this control distinguishes between “application tools” and “infrastructure APIs”)
- EE-03: Resource usage limiting (agents must have bounded CPU/memory/network/storage/API-rate limits; exceeding limits triggers alerts and may terminate the agent)
- EE-04: Evaluation sandbox integrity (evaluation/test environments must be isolated from production with no network path; models must not be able to distinguish evaluation from production environments; evaluation pipelines must not modify production systems)
- EE-05: Host-trusted configuration file injection prevention (agents must not be able to write files that the host OS or host applications will later execute or load as trusted configuration — covering startup files like .zshrc, .bashrc, .profile; IDE/editor configuration files like .vscode/settings.json, .claude/settings.json, .cursor/hooks; version control configuration files like .git/config, .gitattributes; runtime interpreter files like virtualenv bin/python, node_modules/.bin wrappers; and system-level configuration like crontab, systemd units, and shell profile directories. Implementation: write-path allowlisting with explicit exclusion of known host-trusted paths; filesystem integrity monitoring on host-trusted directories; content scanning for configuration-file injection patterns; and host-side isolation that prevents agent-written files from being automatically executed or loaded by host tooling)
- EE-06: Fail-closed sandbox operation (agent execution environments must verify at runtime that the strongest configured isolation mode is actually active, and must FAIL CLOSED — halt execution and alert — rather than silently degrading to a weaker sandbox when the primary sandbox becomes unavailable; this addresses the fail-open sandbox fallback class: agent frameworks that fall back to an insecure interpreter environment when the container runtime is unavailable (CrewAI CVE-2026-2275/2287 — the Code Interpreter tool automatically falls back to an unsafe SandboxPython environment if Docker cannot be reached, enabling arbitrary C function calls via ctypes, and CVE-2026-2286 SSRF can be used to trigger the Docker disruption and force the fallback; the Lyrie Research “When Prompts Become Shells” analysis identified silent fail-open sandbox fallback as a systemic agentic-framework RCE pattern in 2026). Implementation:

continuous sandbox-mode attestation — verify the container/VM is present and enforcing isolation before each code execution step; explicit sandbox-availability checks with no fallback code path; alerts on any sandbox degradation; treat sandbox-unavailable events as potential indicators of compromise via MIR-01)

- EE-07: Agent control-plane configuration integrity (agents must not be able to modify the configuration that governs their own security controls — sandbox mode, approval policy, tool permissions, or hook definitions — and agent tooling must not load configuration from writable shared directories; this addresses the agent self-configuration poisoning class: an agent writing its own .codex/config.toml to set sandbox_mode=workspace-write, approval_policy=never, and notify hooks that execute outside the sandbox (Cymulate, “The Race to Ship AI Tools Left Security Behind”); and configuration trust failures where a low-privileged local user plants a malicious managed-settings.json in a world-writable directory (C:) that privileged AI coding tools load for all users, enabling privilege escalation across Claude Code, Cursor, Codex CLI, and Gemini CLI (CVE-2026-35603). Implementation: agent security configuration files must be read-only to the agent process (mount config read-only, deny writes to .codex/, .claude/, .cursor/ control files); validate directory ownership and permissions before loading any system-wide agent configuration; reject configuration from world-writable paths; monitor for unexpected modifications to agent control-plane configuration via MIR-01)

**Implementation guidance (L2+):** Deploy agent execution within Kubernetes pods (or equivalent container orchestration) with the following hardening: (1) read-only root filesystem, (2) no privileged containers, (3) seccomp/apparmor profiles that block mount, namespace, and process-control syscalls, (4) NetworkPolicy that restricts egress to only registered tool endpoints, (5) resource quotas (CPU, memory, ephemeral storage) that are enforced by the container runtime, (6) Pod Security Admission (or equivalent) at “restricted” profile level, (7) no service account tokens mounted unless explicitly required and scoped per best practice. For VM-level isolation (e.g., Claude Cowork-style deployments), ensure: no shared filesystem mounts between VM and host, no 9p/virtiofs passthrough that enables host filesystem access, microVM or lightweight VM with minimal device emulation, and remote attestation at boot.

**AU framework mappings:** ISM (Guidelines for gateways, system hardening, system management), ASD Container Security Guidance, Essential Eight (Application

Control, Restrict Administrative Privileges), ISM (Guidelines for network management – network segmentation)

## 2.3 Maturity Model

SHIELD-AI defines four maturity levels, consistent with ISM's implementation approach and the Essential Eight's maturity model:

| Level | Name | Description | Typical Entity |
|---|---|---|---|
| L1 | Initial | Ad-hoc AI security; basic controls for model deployment; no formal governance | Startups, AI experimentation, PoCs |
| L2 | Managed | Documented controls for priority AI systems; basic monitoring; vendor assessment for model providers | Small-medium enterprises, early adopters |
| L3 | Defined | Enterprise-wide AI security program; automated controls; integrated monitoring and IR; full regulatory mapping | Regulated entities, government agencies, large enterprises |
| L4 | Optimised | Continuous improvement; AI-specific threat intelligence; automated red-teaming; proactive control evolution | Critical infrastructure, national security, top-tier regulated entities |

### Maturity Progression by Pillar

| Control Area | L1 | L2 | L3 | L4 |
|---|---|---|---|---|
| MS (Model) | Basic model inventory | Supply chain verification | Adversarial testing programme | Automated red-teaming |

| Control Area | L1 | L2 | L3 | L4 |
|---|---|---|---|---|
| IAM (Identity) | Shared credentials | Per-agent service accounts, scope-limited credentials | JIT access, approval gates, delegation chain enforcement | Continuous credential rotation, transitive chain verification, multi-tenant isolation |
| DS (Data) | Basic data classification | Memory sanitisation enforced | End-to-end inference encryption | Real-time data leak detection |
| TP (Tools) | Informal tool list | Tool registry with access control, cross-tool analysis | API gateway with schema validation, infrastructure-isolation mode, explicit tool registration | Automated dependency scanning + sandbox library classification |
| EE (Execution) | Container used but untuned | Read-only root filesystem, NetworkPolicy, control-plane config integrity | seccomp/ apparmor, host file-injection prevention, fail-closed sandbox operation | Remote attestation, runtime boundary verification |
| MIR (Monitoring) | Basic logging | Structured audit logs | Anomaly detection, IR playbooks | AI-specific SIEM integration |
| GRM (Governance) | No formal governance | AI risk register established | Board reporting, regulatory mapping | Automated compliance attestation |




SHIELD-AI maturity model: L1 Initial through L2 Managed, L3 Defined to L4 Optimised with time estimates.

## 2.4 Regulatory Mapping

A core differentiator of SHIELD-AI is its explicit, auditable mapping to the frameworks Australian organisations must comply with. The following table shows a representative sample:

| SHIELD-AI Control | ISM Ref | E8 Ref | SOCI Act | CPS 234 | Privacy Act |
|---|---|---|---|---|---|
| MS-01: Model weight protection | ISM-1xxx (cryptography) | - | CIRMP s.4(a) | s.3(b) | APP 11 |
| IAM-01: Agent identity | Guidelines for system management | Restrict Admin Privs | - | s.3(b) | - |
| IAM-02: Scope-bound delegation | Guidelines for system management | - | CIRMP s.4(b) | s.3(a) | - |
| DS-01: Data classification | Guidelines for data transfers | - | - | s.3(a) | APP 5, 6 |
| DS-02: Inference data protection | Guidelines for cryptography | MFA | - | s.3(b) | APP 11 |
| | | - | - | - | APP 11 |

| SHIELD-AI Control | ISM Ref | E8 Ref | SOCI Act | CPS 234 | Privacy Act |
|---|---|---|---|---|---|
| DS-06: Output validation | Guidelines for software dev | | | | |
| TP-01: Tool registry | Guidelines for gateways | Patch Apps | CIRMP s.4(c) | s.3(b) | - |
| MIR-01: Activity logging | Guidelines for system monitoring | - | s.30B(5)(a) | s.3(c) | NDB |
| MIR-05: Mandatory reporting | Guidelines for incident mgmt | - | s.30B(5)(c) | s.3(c) | NDB |
| GRM-01: AI governance body | Guidelines for cyber security roles | - | CIRMP s.4(d) | s.2 | APP 1 |

> **Note:** A full control-by-control mapping to all 1,081 ISM controls, 24 Essential Eight maturity descriptors, 11 SOCI obligation categories, CPS 234 criteria, and 13 APPs is maintained as a separate reference document. This summary table demonstrates the mapping methodology.

---

# Part 3: Reference Implementation Architecture

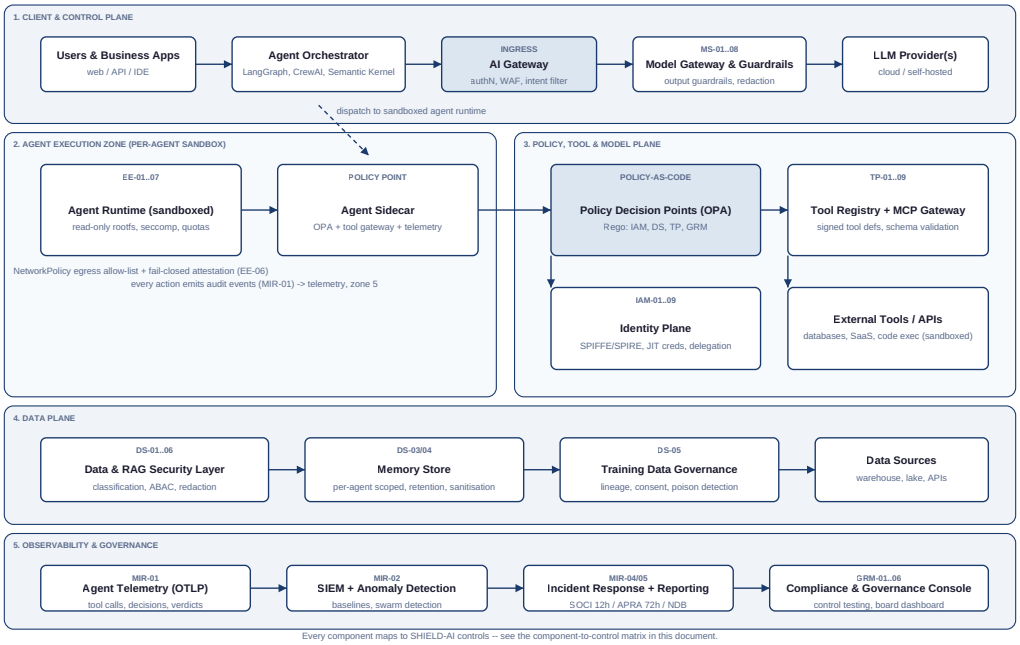
SHIELD-AI is a control framework, but controls must be realised as **deployable components**. This part summarises the deployable component model; the full treatment – component inventory, reference architecture diagrams, request flows, telemetry pipeline, network boundary model, deployment topologies, and the component-to-control mapping matrix for all 51 controls – is maintained in the companion document `framework/shield-ai-implementation-architecture.md` (Markdown, PDF, and EPUB).

## 3.1 The Component Model

An implementation of SHIELD-AI is composed of eight deployable component groups, each realising a defined subset of the 51 controls:

| # | Component Group | What it Deploys | Primary Controls |
|---|---|---|---|
| 1 | Agent runtime & sandbox | Container/VM execution environment: read-only rootfs, seccomp/ AppArmor, NetworkPolicy, resource quotas, fail-closed sandbox attestation | EE-01..EE-07 |
| 2 | Model gateway & guardrails | Inference proxy with output guardrails, adversarial test harness, model registry integration | MS-01..MS-08 |
| 3 | Identity plane | Agent identities (SPIFFE/ SPIRE or service accounts), just-in-time credentials, delegation chain enforcement | IAM-01..IAM-09 |
| 4 | Data & RAG security layer | Classification pipeline, attribute-based access control at retrieval, field-level redaction, memory sanitisation | DS-01..DS-06 |
| 5 | Tool gateway / sidecar proxy | Tool registry, MCP gateway, schema validation, rate limiting, tool output validation | TP-01..TP-09 |
| 6 | Policy decision points (OPA) | Policy-as-code engine evaluating Rego assertions on every agent action | IAM, DS, TP, GRM |
| 7 | Telemetry & SIEM pipeline | Structured agent events (OTLP), behavioural | MIR-01..MIR-06 |

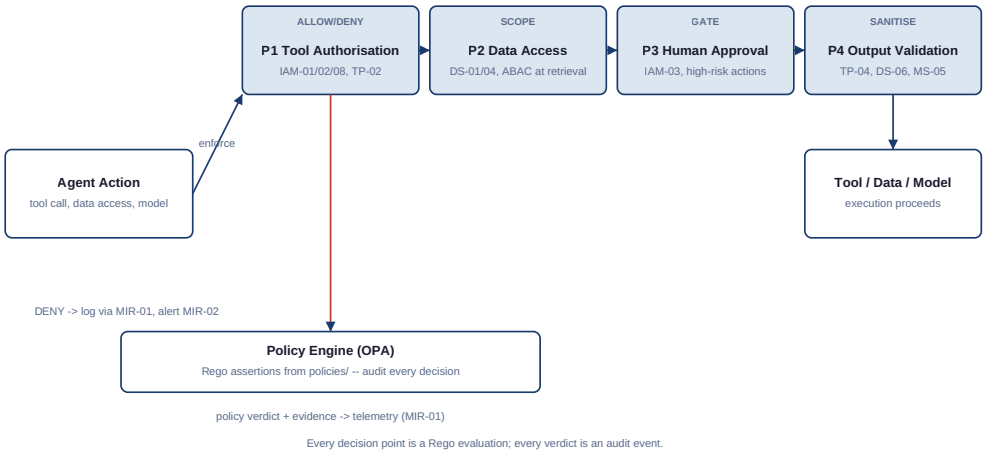
| # | Component Group | What it Deploys | Primary Controls |
|---|---|---|---|
| | | anomaly detection, prompt audit log, forensic store | |
| 8 | Compliance & governance console | Continuous control testing, regulatory mapping, board dashboard, AI risk register | GRM-01..GRM-06 |




Reference implementation: deployable component view.

## 3.2 Policy-as-Code

The framework's "verifiable by default" principle (Section 2.1) is realised by the policy-as-code layer. Each control is expressed as a machine-readable assertion; the repository ships per-control Rego stubs in `policies/` for the Open Policy Agent evaluation layer. Every agent action – tool invocation, data access, model call, delegation – is evaluated against the applicable policy before it is permitted, and every decision is emitted to the telemetry pipeline (MIR-01).

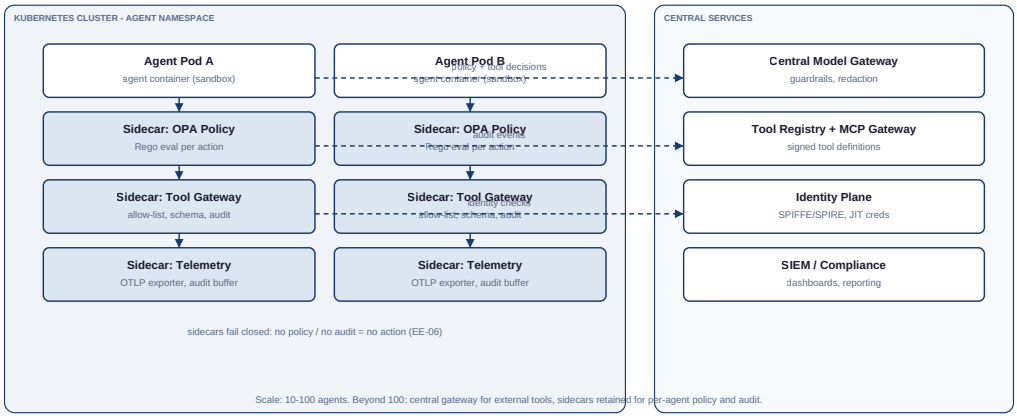



Policy decision points along the agent action path.

## 3.3 Deployment Topologies

The component model deploys in one of three topologies, selected by agent fleet size and isolation requirements (full decision guidance is in the implementation architecture document):

- **Embedded library** – fewer than ~10 agents; controls run inside the agent framework.
- **Sidecar proxy** – ~10-100 agents; a per-agent sidecar (policy engine + tool gateway + telemetry) in a container-orchestrated deployment.
- **Central gateway + sidecars** – 100+ agents or multi-agent systems; central policy/gateway for external tools with per-agent sidecars for monitoring.




Sidecar deployment topology in a container orchestrator.

# Part 4: Implementation Journey

## 4.1 Framework Maturity Journey

An organisation adopting SHIELD-AI follows a progressive implementation journey:




SHIELD-AI maturity journey: L1 Initial to L4 Optimised.

### Typical progression

| Starting Level | Target Level | Indicative Duration |
|---|---|---|
| L1 (None) | L2 (Managed) | 3-4 months |
| L1 (None) | L3 (Defined) | 8-12 months |
| L2 (Managed) | L3 (Defined) | 4-6 months |
| L3 (Defined) | L4 (Optimised) | 12+ months |

Maturity is determined by the **weakest pillar**: overall maturity cannot exceed the lowest-scoring pillar. Progression sequencing should therefore address the weakest pillar first, then the highest-risk controls within each pillar (see the Assessment Guide's maturity progression paths).

# Part 5: Future Horizons – Agentic AI Trends 2026-2029

## 5.1 Why Future-Proofing Matters Now

The SHIELD-AI framework was designed from the outset to be evolvable – its seven-pillar structure accommodates new control areas without requiring re-architecture. This section identifies the key trends, threats, and regulatory developments expected over the next 2-3 years, and maps them to specific SHIELD-AI controls that will need to evolve. Organisations that plan for these developments today will avoid the "bolt-on compliance" trap that has plagued earlier security frameworks.

## 5.2 Emerging Agentic AI Deployment Trends

### Trend 1: Multi-Agent Systems and Agent Swarms

**What is happening:** Organisations are moving from single-agent deployments (one agent performing one task) to multi-agent architectures where specialised agents coordinate, delegate tasks, and share context. Agent swarms – collections of agents with different roles – introduce complex trust relationships between agents.

**Security implications for SHIELD-AI:**

- **IAM-02 (Scope-bound delegation)** must evolve to cover agent-to-agent delegation, not just human-to-agent. An agent that delegates to another agent must not expand the scope of the original authorisation – the delegation chain must be bounded at each hop.
- **IAM-06 (Cross-session boundary)** must cover inter-agent communication channels. Agents that share a context window must have explicit data-sharing agreements enforced at the infrastructure layer, not just by convention.
- **MIR-01 (Activity logging)** must support session tracing across agent boundaries. A single user request triggering a chain of agent calls must be reconstructable as a single audit trail.

- **TP-01 (Tool registry)** must cover agent-to-agent APIs as a tool class. Agents that expose functions to other agents must be registered, versioned, and security-approved just like external tool endpoints.

**Timeline:** Multi-agent production deployments are already occurring in 2026. By 2027-2028, they will be the dominant deployment pattern. Organisations at SHIELD-AI L3 should plan for agent-to-agent security now.

## Trend 2: Model Context Protocol (MCP) and Standardised Agent-Tool Interfaces

**What is happening:** The Model Context Protocol (MCP) is emerging as a standardised way for AI agents to discover and invoke tools. Similar to how HTTP standardised web communication, MCP standardises the agent-tool interface. This is a positive development for security – standard interfaces enable standard security controls – but also introduces a single protocol-layer attack surface.

**Security implications for SHIELD-AI:**

- **TP-03 (API gateway security)** must extend to MCP endpoints. MCP gateways that sit between agents and tools must enforce schema validation, rate limiting, and authentication at the protocol layer, not just at the HTTP layer.
- **TP-04 (Tool output validation)** must understand MCP response schemas. Standardised tool-output formats (MCP responses) must be validated against known-good schemas before being fed back into agent context.
- **MS-04 (Adversarial robustness)** must include MCP protocol-layer attacks – tool discovery poisoning, capability advertisement manipulation, and protocol-level prompt injection through tool descriptions.

**Timeline:** MCP adoption is accelerating through 2026. SHIELD-AI L3+ clients should have MCP-aware security controls by early 2027.

## Trend 3: Persistent Agent Memory and State Management

**What is happening:** Early agentic AI deployments used stateless, session-bound interactions. The next generation maintains persistent memory – agents that remember users, preferences, past decisions, and long-running tasks across sessions. This creates data aggregation risk at a systemic level.

**Security implications for SHIELD-AI:**

- **DS-03 (Memory sanitisation)** is the highest-priority control in this trend. Persistent memory stores must implement data retention policies, automated purging of sensitive data, and cross-session aggregation detection.
- **DS-04 (Data minimisation)** must apply to memory stores. Agents should not remember data they do not need for their function. Memory must be scoped per-agent and per-task, not shared across agents by default.
- **DS-06 (Output validation)** must include memory-read attacks – an attacker who compromises one session should not be able to read data from another session through shared memory.
- **MIR-02 (Anomaly detection)** must baseline memory access patterns. An agent that suddenly accesses memory records from weeks ago is a potential indicator of compromise.

**Timeline:** Persistent memory is available in major platforms today (OpenAI Memory, Anthropic Projects, open-source RAG agents). Controls should be at L2+ by end of 2026.

## Trend 4: Agent-as-a-Service (AaaS) and Managed Agent Platforms

**What is happening:** Cloud providers and AI vendors are offering managed agent platforms – fully hosted environments where clients define agent behaviour via configuration. This shifts security responsibility to the platform provider for infrastructure controls, but the client remains responsible for agent behaviour, data protection, and regulatory compliance.

**Security implications for SHIELD-AI:**

- **GRM-04 (Third-party AI risk management)** becomes the critical control. Clients using AaaS must assess the provider's security controls, understand shared responsibility models, and retain contractual rights to audit agent behaviour.
- **DS-02 (Inference data protection)** must cover provider-side inference. Data sent to managed agent platforms for inference must be protected with contractual encryption guarantees and, where possible, client-side encryption keys.
- **IAM-01 (Agent identity)** must work across platform boundaries. An agent that uses tools on-premise and in the cloud must maintain a consistent identity across both environments.

- **TP-05 (Pipeline integrity)** must cover managed platform deployment pipelines. Client-controlled CI/CD gates must be supplemented with platform-provided security attestations.

**Timeline:** All major cloud providers are launching or have launched AaaS offerings in 2025-2026. Third-party AI risk management (GRM-04) should be at L3 for any organisation using AaaS in 2027.

## Trend 5: Autonomous Code Generation and Self-Healing Agents

**What is happening:** Agents are increasingly able to generate, modify, and execute code – not just call fixed tools. This includes agents that write database queries, generate shell commands, modify configuration files, and even patch their own code. This is the highest-risk capability an agent can possess.

**Security implications for SHIELD-AI:**

- **TP-01 (Tool registry)** must include "code execution" as a distinct tool class with the highest security requirements. Code-generation tools must require human approval for production writes.
- **TP-04 (Tool output validation)** must include code-output validation – generated code must be sandbox-executed and output-verified before affecting production systems.
- **MIR-04 (Incident response)** must include code-injection containment playbooks. An agent that generates malicious code requires different containment (revoke code-execution tool, roll back affected systems) than a prompt-injected agent.
- **IAM-03 (Human oversight)** must require explicit human approval for any agent-generated code that modifies production infrastructure, data, or user-facing behaviour.

**Timeline:** Code-generating agents are in early production use (GitHub Copilot, Cursor, Devin-like agents). Restrictive controls should be L2+ by 2027; permissive controls should require L4-level monitoring.

## Trend 6: Edge-Based and On-Device Agent Deployment

**What is happening:** As small language models improve (phi-4, Llama 3.2 1B, Gemma 3), agentic capabilities are being deployed on edge devices – phones, IoT gateways, vehicles, and industrial controllers. These deployments lack the infrastructure controls of cloud environments.

**Security implications for SHIELD-AI:**

- **MS-01 (Model weight protection)** becomes critical for edge deployments. Model weights on edge devices must be encrypted, integrity-checked at boot, and remotely attestable.
- **TP-06 (Dependency scanning)** must cover edge device dependencies. Supply chain security for edge agents includes the device firmware, OS, ML runtime, and model.
- **MIR-06 (Forensic readiness)** must support disconnected operation. Edge agents must log locally with integrity guarantees and synchronise logs when connectivity is restored.
- **DS-02 (Inference data protection)** must apply to on-device inference. Data processed on edge devices may not have the same physical security protections as cloud data centres.

**Timeline:** Edge agent deployment is nascent (2026) but growing rapidly with on-device ML improvements. SHIELD-AI edge controls should be at L2 reference by 2027, L3 by 2028.

## 5.3 Foreseeable Regulatory Developments

### Australian AI Regulation – Mandatory Guardrails

**Expected:** The Australian Government has signalled mandatory AI guardrails for high-risk AI systems, likely legislated by 2027-2028. The current voluntary framework (10 guardrails published by DISR) will transition to mandatory obligations with enforcement mechanisms.

**Action for SHIELD-AI:** The framework's GRM pillars and maturity model are designed to map directly to the guardrails framework. When guardrails become mandatory, SHIELD-AI at L3+ should constitute a presumption of compliance. The consultancy should position for this transition by publishing a "Guardrails-to-SHIELD-AI" mapping in 2026-2027.

## EU AI Act Extraterritorial Effect

**Expected:** The EU AI Act's extraterritorial scope means Australian organisations deploying or using AI systems that affect EU residents must comply. This includes risk classification, conformity assessment, and incident reporting.

**Action for SHIELD-AI:** The framework's MIR and GRM controls already align with EU AI Act requirements for incident reporting and governance. A formal EU AI Act mapping appendix should be added by 2027.

## APRA CPG 230 and AI-Specific Prudential Guidance

**Expected:** APRA is expected to update CPG 230 with AI-specific guidance for regulated entities, following consultation in 2025-2026. This will cover model risk management, explainability, and board accountability for AI decisions.

**Action for SHIELD-AI:** The MS (Model Security) and GRM (Governance) pillars are already positioned for this. APRA-regulated clients should be at SHIELD-AI L3 by 2028 to meet expected guidance.

## OAIC Guidance on AI and Privacy

**Expected:** The OAIC has been active on AI and privacy, with enforceable guidance expected by 2027. This will likely cover automated decision-making, data aggregation by AI systems, and transparency obligations.

**Action for SHIELD-AI:** The DS (Data Security) pillar's controls – particularly DS-01 (classification), DS-04 (minimisation), and DS-06 (output validation) – directly address OAIC concerns. Formal OAIC guidance mapping should be published alongside the framework.

---

# Part 6: Governance and Evolution

## 6.1 Framework Governance

SHIELD-AI is maintained by the consulting practice's Security Architecture Practice Lead, overseen by a **Framework Steering Group** comprising:

- Practice Lead (Chair)
- Technical AI Security Lead
- Regulatory Compliance Lead
- Client Advisory Board (2-3 senior client CISOs)
- External Advisor (academic AI safety researcher or ex-regulator)

The steering group meets quarterly to review:

- Regulatory changes (ISM updates, new legislation, OAIC/APRA guidance)
- Threat landscape evolution (new AI attack techniques, vulnerability classes)
- Framework adoption feedback (what works, what needs refinement)
- Control additions or modifications

## 6.2 Versioning and Release Cadence

| Version | Trigger | Process |
|---|---|---|
| Patch (v1.0 -> v1.1) | ISM update, minor control refinement | Practice lead approval, updated mapping table |
| Minor (v1.x -> v2.0) | New regulatory obligation, new attack vector class | Steering group review, 4-week consultation |
| Major (v1.x -> v2.x) | Fundamental framework change | 8-week consultation including select client feedback |

## 6.3 Certification Path

For clients requiring formal recognition:

- SHIELD-AI Practitioner (internal team member trained in framework application)
- SHIELD-AI Assessor (authorised to perform independent SHIELD-AI assessments)
- SHIELD-AI Certified Organisation (organisation assessed at target maturity level)

Certification is optional – most clients will use the framework for self-assessment and regulatory compliance without formal certification.

# Appendix A: Glossary

| Term | Definition |
|---|---|
| Agentic AI | An AI system that can autonomously perceive, reason, act, and learn across multi-step workflows with tool access |
| Tool delegation | The mechanism by which an agent invokes external tools, APIs, or systems |
| Prompt injection | An attack where crafted input causes an AI model to behave outside intended parameters |
| Agent identity | The digital identity under which an agent operates, distinct from the human user who initiated it |
| Control | A safeguard, policy, or technical mechanism that mitigates a specific security risk |
| Maturity level | A defined stage of security capability, from ad-hoc (L1) to continuously optimised (L4) |
| Guardrail | Technical controls that constrain model behaviour, typically at inference time |
| Agent SBOM | A software bill of materials for an agentic AI system, including model, tools, libraries, and pipeline |

# Appendix B: Quick-Reference Pillar Summary

| Pillar | Focus | Key Question Stakeholders Should Ask |
|---|---|---|
| MS | Model | “Do we know where our models come from and how they behave?” |
| IAM | Identity | “Can our agents do anything the user can do?” |
| DS | Data | “Is our data exposed to the model, and is it protected?” |
| TP | Tools | “What tools can our agents call, and is that controlled?” |
| EE | Execution Environment | “Can the agent escape its sandbox?” |
| MIR | Monitoring | “Would we know if an agent was compromised?” |
| GRM | Governance | “Who is accountable for AI security, and can they demonstrate it?” |

# Appendix C: Emerging Standards and Framework Cross-Mapping

The following table maps each SHIELD-AI control to emerging international and national standards, frameworks, and regulatory instruments that are expected to become binding or market-relevant over the 2026-2029 horizon.

| SHIELD-AI Control | OWASP LLM Top 10 v2 | NIST AI RMF 1.0 | EU AI Act | ISO/ IEC 42001 | Google SAIF | MITRE ATLAS | AU M Guar (prop |
|---|---|---|---|---|---|---|---|
| **MS-01: Model weight protection** | - | IDENTIFY (ID.MP) | Art. 9 Risk Mgmt | Clause 8.2 | Asset Protection | ML Supply Chain Compromise | Guar (Gov |
| | | IDENTIFY (ID.DA) | Art. 10 Data Governance | Clause 8.3 | Data Governance | | Guar (Data |

| SHIELD-AI Control | OWASP LLM Top 10 v2 | NIST AI RMF 1.0 | EU AI Act | ISO/ IEC 42001 | Google SAIF | MITRE ATLAS | AU M Guar (prop |
|---|---|---|---|---|---|---|---|
| **MS-02: Training data integrity** | LLM04 (Data Poisoning) | | | | | Training Data Poisoning | |
| **MS-03: Supply chain security** | LLM10 (Supply Chain) | IDENTIFY (ID.SC) | Art. 12 Transparency | Clause 7.2 | Supply Chain Security | ML Supply Chain | Guar (Tran |
| **MS-04: Adversarial robustness** | LLM01 (Prompt Injection), LLM05 (Jailbreak) | MEASURE (ME.AD) | Art. 15 Accuracy | Clause 8.5 | Red Teaming | Prompt Injection, Jailbreak | Guar (Safe |
| **MS-05: Behaviour validation** | LLM02 (Insecure Output) | MANAGE (MG.DE) | Art. 14 Human Oversight | Clause 8.6 | Safe Responses | Output Integrity | Guar (Hum Overs |
| **MS-06: Model inventory** | - | GOVERN (GV.OD) | Art. 11 Registration | Clause 7.4 | Asset Inventory | - | Guar (Gov |
| **IAM-01: Agent identity** | - | IDENTIFY (ID.AM) | Art. 15(b) Access Control | Clause 8.4 | Access Control | Identity Abuse | Guar (Acc |
| **IAM-02: Scope-bound delegation** | LLM08 (Excessive Agency) | GOVERN (GV.AC) | Art. 14(b) | Clause 8.4 | Least Privilege | Excessive Agency | Guar (Acc |
| **IAM-03: Human oversight** | - | MANAGE (MG.DE) | Art. 14 (Human Oversight) | Clause 8.3 | Human-in-the-Loop | - | Guar (Hum Overs |
| **IAM-04: Credential isolation** | - | PROTECT (PR.AC) | Art. 15(b) | Clause 8.4 | Credential Mgmt | Credential Access | Guar (Secu |
| **DS-01: Data classification** | LLM06 (Sensitive Info) | IDENTIFY (ID.DA) | Art. 10 Data Governance | Clause 8.3 | Data Classification | Data Exfiltration | Guar (Data |
| | - | PROTECT (PR.DS) | Art. 15(c) | Clause 8.4 | Data Protection | Inference Evasion | Guar (Secu |

| SHIELD-AI Control | OWASP LLM Top 10 v2 | NIST AI RMF 1.0 | EU AI Act | ISO/ IEC 42001 | Google SAIF | MITRE ATLAS | AU M Guar (prop |
|---|---|---|---|---|---|---|---|
| **DS-02: Inference data protection** | | | | | | | |
| **DS-03: Memory sanitisation** | LLM06 (Sensitive Info) | PROTECT (PR.DS) | Art. 10(4) | Clause 8.3 | Data Lifecycle | Data from Memory | Guar (Data |
| **DS-04: Data minimisation** | - | IDENTIFY (ID.DA) | Art. 10(2) | Clause 8.3 | Data Minimisation | - | Guar (Data |
| **DS-05: Training data governance** | LLM04 (Data Poisoning) | IDENTIFY (ID.DA) | Art. 10 Data Governance | Clause 8.3 | Data Lineage | Training Data | Guar (Data |
| **DS-06: Output validation** | LLM02 (Insecure Output) | MEASURE (ME.AD) | Art. 15(a) | Clause 8.6 | Output Safety | Output Integrity | Guar (Safe |
| **TP-01: Tool registry** | LLM08 (Excessive Agency) | IDENTIFY (ID.AM) | Art. 15(b) | Clause 7.2 | Tool Inventory | Tool Abuse | Guar (Secu |
| **TP-02: Tool access control** | LLM08 (Excessive Agency) | PROTECT (PR.AC) | Art. 14(b) | Clause 8.4 | Access Control | Tool Abuse | Guar (Acc |
| **TP-03: API gateway security** | - | PROTECT (PR.AC) | Art. 15(b) | Clause 8.4 | API Security | API Abuse | Guar (Secu |
| **TP-04: Tool output validation** | LLM02 (Insecure Output) | MEASURE (ME.AD) | Art. 15(a) | Clause 8.6 | Output Integrity | Tool Output Poisoning | Guar (Safe |
| **TP-05: Pipeline integrity** | LLM10 (Supply Chain) | PROTECT (PR.CI) | Art. 9(4) | Clause 7.5 | CI/CD Security | Supply Chain Compromise | Guar (Secu |
| **TP-06: Dependency scanning** | LLM10 (Supply Chain) | IDENTIFY (ID.RM) | Art. 9(4) | Clause 7.5 | Dependency Mgmt | Dependency Abuse | Guar (Secu |
| | | | Art. 15(b) | | | Tool Abuse | |

| SHIELD-AI Control | OWASP LLM Top 10 v2 | NIST AI RMF 1.0 | EU AI Act | ISO/ IEC 42001 | Google SAIF | MITRE ATLAS | AU M Guar (prop |
|---|---|---|---|---|---|---|---|
| **TP-09: Explicit tool registration** | LLM08 (Excessive Agency) | IDENTIFY (ID.AM) | | Clause 7.2 | Tool Inventory | | Guar (Acc |
| **MIR-01: Activity logging** | - | DETECT (DE.AE) | Art. 12 Transparency | Clause 8.6 | Audit Logging | - | Guar (Mon |
| **MIR-02: Anomaly detection** | - | DETECT (DE.CM) | Art. 14(c) | Clause 8.5 | Anomaly Detection | Discovery & Recon | Guar (Mon |
| **MIR-03: Prompt audit log** | LLM01 (Prompt Injection) | DETECT (DE.AE) | Art. 12(1) | Clause 8.6 | Audit Trail | Prompt Injection | Guar (Mon |
| **MIR-04: Incident response** | - | RESPOND (RS.RP) | Art. 20 Incident Rpt | Clause 8.7 | Incident Response | - | Guar (Incid |
| **MIR-05: Mandatory reporting** | - | RESPOND (RS.CO) | Art. 20(1) Serious Incidents | Clause 8.7 | - | - | Guar (Incid |
| **MIR-06: Forensic readiness** | - | RECOVER (RC.RP) | Art. 9(3) | Clause 8.6 | - | - | Guar (Mon |
| **GRM-01: AI governance body** | - | GOVERN (GV.OD) | Art. 17 (Designated Rep) | Clause 5.1 | Governance | - | Guar (Gov |
| **GRM-02: AI risk register** | - | GOVERN (GV.RM) | Art. 9 Risk Mgmt | Clause 6.1 | Risk Assessment | Risk Register | Guar (Gov |
| **GRM-03: Ethical use policy** | - | GOVERN (GV.OC) | Art. 14 Human Oversight | Clause 5.2 | Responsible AI | - | Guar (Fair |
| **GRM-04: Third-party AI risk mgmt** | LLM10 (Supply Chain) | IDENTIFY (ID.SC) | Art. 28 (Third Parties) | Clause 7.2 | Vendor Risk | Supply Chain | Guar (Tran |
| | - | | | | Compliance | - | |

| SHIELD-AI Control | OWASP LLM Top 10 v2 | NIST AI RMF 1.0 | EU AI Act | ISO/ IEC 42001 | Google SAIF | MITRE ATLAS | AU M Guar (prop |
|---|---|---|---|---|---|---|---|
| **GRM-05: Regulatory mapping** | | GOVERN (GV.OV) | Art. 26 Compliance | Clause 7.3 | | | Guar (Gov |
| **GRM-06: Board reporting** | - | GOVERN (GV.OV) | Art. 17(2) | Clause 9.1 | - | - | Guar (Gov |
| **IAM-09: Multi-tenant isolation** | - | PROTECT (PR.AC) | Art. 15(b) | Clause 8.4 | Access Control | - | Guar (Acc |
| **EE-06: Fail-closed sandbox op** | - | PROTECT (PR.PT) | Art. 15(b) | Clause 8.4 | - | - | Guar (Secu |
| **EE-07: Control-plane config integrity** | - | PROTECT (PR.AC) | Art. 15(b) | Clause 8.4 | - | - | Guar (Secu |
| **MS-07: Deployment context obfuscation** | - | MANAGE (MG.DE) | Art. 15(a) | Clause 8.5 | - | Evaluation Subversion | Guar (Safe |
| **MS-08: MCP security controls** | LLM02 (Insecure Output) | PROTECT (PR.AC) | Art. 15(b) | Clause 8.4 | API Security | Tool Output Poisoning | Guar (Secu |
| **IAM-05: Just-in-time access** | - | PROTECT (PR.AC) | Art. 15(b) | Clause 8.4 | Least Privilege | Credential Access | Guar (Acc |
| **IAM-06: Cross-session boundary** | - | PROTECT (PR.AC) | Art. 14(b) | Clause 8.4 | Access Control | Session Hijacking | Guar (Acc |
| **IAM-07: Transitive delegation chain** | - | GOVERN (GV.AC) | Art. 14(b) | Clause 8.4 | Least Privilege | Excessive Agency | Guar (Acc |

| SHIELD-AI Control | OWASP LLM Top 10 v2 | NIST AI RMF 1.0 | EU AI Act | ISO/ IEC 42001 | Google SAIF | MITRE ATLAS | AU M Guar (prop |
|---|---|---|---|---|---|---|---|
| **IAM-08: Credential scope narrowing** | - | PROTECT (PR.AC) | Art. 15(b) | Clause 8.4 | Credential Mgmt | Credential Access | Guar (Secu |
| **TP-07: Cross-tool dependency analysis** | LLM08 (Excessive Agency) | MANAGE (MG.DE) | Art. 9(4) | Clause 7.5 | Tool Inventory | Tool Abuse | Guar (Secu |
| **TP-08: Infrastructure-isolation mode** | - | PROTECT (PR.PT) | Art. 15(b) | Clause 8.4 | API Security | - | Guar (Secu |
| **EE-01: Execution boundary enforcement** | - | PROTECT (PR.PT) | Art. 15(b) | Clause 8.4 | - | - | Guar (Secu |
| **EE-02: Infrastructure API access control** | - | PROTECT (PR.AC) | Art. 15(b) | Clause 8.4 | - | - | Guar (Secu |
| **EE-03: Resource usage limiting** | - | PROTECT (PR.PT) | Art. 15(b) | Clause 8.4 | - | Resource Exhaustion | Guar (Secu |
| **EE-04: Evaluation sandbox integrity** | - | GOVERN (GV.OD) | Art. 15(a) | Clause 8.5 | - | Evaluation Subversion | Guar (Safe |
| **EE-05: Host-trusted file injection prevention** | - | PROTECT (PR.DS) | Art. 15(a) | Clause 8.4 | - | - | Guar (Secu |

## Standards Maturity Assessment

| Standard/ Framework | Status | SHIELD-AI Integration Level | Expected Relevance Peak |
|---|---|---|---|
| OWASP LLM Top 10 v2 | Published 2025 | Full control mapping | 2026-2028 |
| NIST AI RMF 1.0 | Published January 2023 | Full control mapping (all 4 functions) | 2026-2028 |
| NIST AI 600-1 (AI Risk Profile) | In development | Tracked for L4 maturity alignment | 2027-2029 |
| EU AI Act | In force August 2024, phased implementation | Full mapping for extraterritorial applicability | 2027-2029 |
| ISO/IEC 42001:2025 | Published late 2025 | Mapped to AI management system clauses | 2027-2029 |
| ISO/IEC 42005 (AI Impact Assessment) | In development | Tracked for L3+ governance alignment | 2028-2029 |
| Google SAIF | Published 2024 | Cross-mapped for multi-cloud environments | 2026-2028 |
| MITRE ATLAS | Ongoing | Tracked for attack technique coverage | 2026-2029 |
| AU Mandatory AI Guardrails | Proposed, legislation expected 2027-2028 | Full mapping anticipated | 2027-2029 |
| Singapore AI Verify | Published 2024 | Cross-reference for APAC alignment | 2026-2028 |
| UK AI Safety Institute testing | Active 2025+ | Red-teaming methodology reference (MS-04) | 2026-2029 |
| | MCP Security Specification | Emerging 2025-2026 — active CVEs July 2026 | MS-08 (MCP security controls), TP-03, TP-04 |

### Emerging Capability: Continuous Compliance Automation

A key differentiator for the SHIELD-AI offering is the transition from periodic assessment to **continuous compliance monitoring**. By 2028, the consultancy should offer:

1. **Automated control testing** – every control expressed as machine-readable assertions (Rego policies, OPA rules, automated test suites) that run against live agentic AI deployments on a continuous basis.
2. **Regulatory change detection** – automated monitoring of ISM updates, new legislation, and OAIC/APRA guidance, with impact analysis mapped to specific SHIELD-AI controls.
3. **Client compliance dashboard** – a SaaS-delivered dashboard showing maturity scores per pillar, regulatory compliance status per framework, open findings, and trend data.
4. **Evidence collection automation** – automated gathering of control evidence (logs, configurations, attestations) for audit readiness, replacing the manual evidence-gathering exercise that annual compliance assessments require.

This capability transforms SHIELD-AI from a point-in-time assessment into an ongoing security operations capability – the continuous compliance model described in Part 4.

---

# Appendix D: Glossary Addendum – Emerging Concepts

| Term | Definition |
|---|---|
| Multi-agent system | An architecture where multiple specialised AI agents coordinate, delegate, and share context to accomplish complex tasks |
| Agent swarm | A collection of heterogeneous agents with different roles operating as a coordinated group |
| Model Context Protocol (MCP) | A standardised protocol for AI agents to discover and invoke external tools, analogous to HTTP for web communication |

| Term | Definition |
| --- | --- |
| Agent-to-Agent (A2A) protocol | An emerging standard for direct communication and task delegation between autonomous agents |
| Agent-as-a-Service (AaaS) | A managed platform offering where agent runtime, orchestration, and infrastructure are provided by a third party |
| Persistent agent memory | Long-term storage of agent state, user preferences, and interaction history across sessions |
| Self-healing agent | An agent that can detect errors in its own operation and autonomously modify its code, configuration, or tool usage to recover |
| Code-generating agent | An agent with the capability to generate, modify, and execute code – the highest-risk agent capability |
| Tool output injection | An attack where a compromised or malicious tool returns crafted output that causes the agent to behave outside intended parameters |
| Agent credential delegation | The mechanism by which an agent inherits or derives access permissions from a user or another agent |
| Policy-as-code | The practice of expressing security and compliance policies as machine-readable, testable assertions (e.g., OPA/Rego policies) |
| Continuous compliance | An approach where control verification runs continuously against live deployments, replacing periodic point-in-time assessments |
| RAG security layer | Security controls embedded in the retrieval-augmented generation pipeline that enforce data access control at retrieval time |
| Agent SBOM | A software bill of materials for an agentic AI system, encompassing model, tools, libraries, pipeline components, and runtime |
| Agent telemetry | Structured event streams from agent operations used for monitoring, anomaly detection, and forensic analysis |
| Shared responsibility model (AI) | The division of security responsibilities between a managed agent platform provider and the client organisation using it |

| Term | Definition |
| --- | --- |
| MCP gateway | A security proxy that enforces authentication, schema validation, rate limiting, and audit logging on MCP-compliant agent-tool communication |

---

*SHIELD-AI v1.4 – August 3, 2026 Authored by the Security Architecture Practice For enquiries: practice-lead@consultancy.example.com*